



Bayesian Phishing Estimation Kit

Bayesian phishing estimation begins with your best pre-test expectation and expresses that belief as a prior distribution that can later be updated with phishing test results.

① Start with your best estimate before seeing results.

- Before you send a phishing test, you usually have some sense of what proportion of users will engage with it.
- That estimate might come from past campaigns, the realism of the message, the target audience, or expert judgment.
- In Bayesian analysis, this starting expectation is called the *prior*.
- The prior does not lock in the result. It is simply your starting point before the data arrive.

② Plot that starting expectation on a Beta distribution.

- To use your prior in the analysis, you place it on a Beta distribution, which is a mathematical curve that represents different possible click-rate levels before you see the data. Taller parts of the curve indicate click rates the model supports more strongly, while shorter parts indicate less support.
- Narrow curves reflect more confidence in a smaller range of click rates.
- Wide curves reflect more uncertainty.
- To do this, you need the click rate you expect on average and the number of prior clicks and prior non-clicks that reflect that belief.
- You do not need to get the prior exactly right. It only needs to reasonably reflect your beliefs. A Beta(2,18), for example, means you expect 2 people to click and 18 to not-click on a phishing link with.
- The plots below show examples of prior beliefs of varying confidence.

Why not just report the click rate and be done?

The observed click rate is useful, but it is still only an estimate of the underlying phishing risk in the larger organization or industry.

If you ran the same phishing test again, the click rate would change. It would vary from test to test, sometimes by enough to understate or overstate the true level of risk.

Bayesian estimation helps by treating the observed click rate as evidence, not as a perfect measure. It combines that evidence with what you believed before the test to produce a more stable and informative estimate.

How the prior is plotted

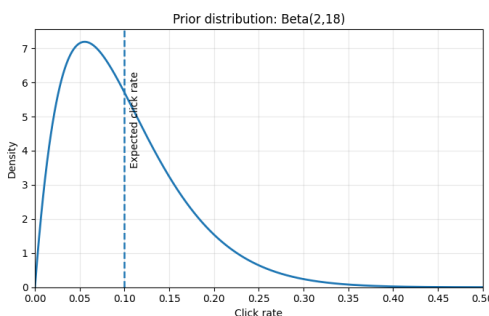
In a Beta distribution, there are two values that determine its shape: (1) alpha represents prior clicks and (2) beta represents prior non-clicks.

- Alpha + beta = prior sample size, or the strength of your prior belief.
- When alpha is larger relative to beta, the prior leans toward higher click rates.
- When beta is larger relative to alpha, the prior leans toward lower click rates.
- A larger prior sample size makes the curve tighter, which means the prior has more influence when the data are updated (see the prior distributions at the bottom of this page).

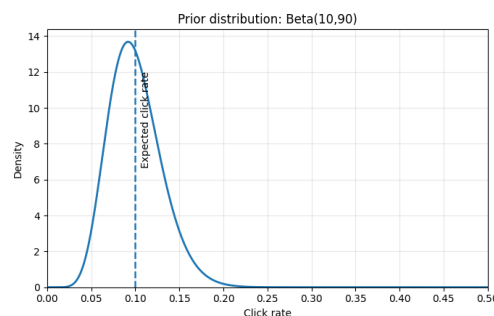


Want help plotting your prior on a Beta distribution? Use this app:
<https://tinyurl.com/54bzckdz>

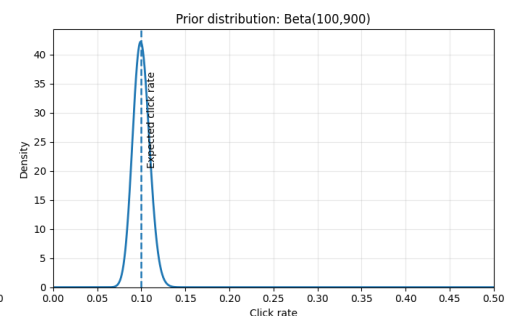
Prior 10% click rates for three Beta distributions based on sample size (20, 100, 1000)



This prior is centered on an expected click rate of about 10% (or 2/20). Lower click rates remain credible, but a 35% click rate or greater has almost no prior support.



This prior is also centered on about 10% (or 10/100), but it is tighter because the prior sample size is larger: 100 rather than 20, reflecting greater confidence in a narrower range of click rates.



This prior is also centered on about 10%, (or 100/1000), and it is tighter still because the prior sample size is 1,000. It reflects a much stronger prior belief.

Bayesian Phishing Estimation Kit

Bayesian updating begins when new campaign data are combined with your prior expectation, producing a posterior estimate that reflects both what you believed before the test and what the evidence now suggests.

③ Update the prior with data from your phishing campaign.

- After the phishing test, record the number of observed clicks and observed non-clicks.
- These observed results are the evidence.

④ Combine the prior with the observed data to create the posterior.

- Add the observed clicks to the prior alpha value.
- Add the observed non-clicks to the prior beta value.
- These updated values define a new Beta distribution called the *posterior*. An example is shown below.

⑤ Use the posterior to interpret phishing risk.

- The posterior gives an updated estimate of the click rate after combining your prior belief with the campaign data.
- It also shows how certain or uncertain that updated estimate is.
- A tighter posterior curve reflects more confidence in a narrower range of click rates.
- A wider posterior curve reflects more uncertainty.

Just a bit of math

Prior alpha + observed clicks = posterior alpha

Prior beta + observed non-clicks = posterior beta

The posterior is the updated Beta distribution after the campaign data are added to the prior.

Example: Prior Beta(2,18) + observed 10 clicks and 90 non-clicks = posterior Beta(12, 108).

Why prior size matters

The update rule shows that the posterior depends on both the prior and the new data. A small prior can be overwhelmed by a large dataset, while a large prior can outweigh a small dataset.

Example where the data dominate the result:

Prior Beta(2, 18) + 100 observed clicks and 900 non-clicks = Beta(102, 918)

The prior sample size is 20; the data size is 1,000.

Example where the prior dominates the result:

Prior Beta(100, 900) + 10 observed clicks and 90 non-clicks = Beta(110, 990)

The prior sample is 1,000 and the data sample is 100.

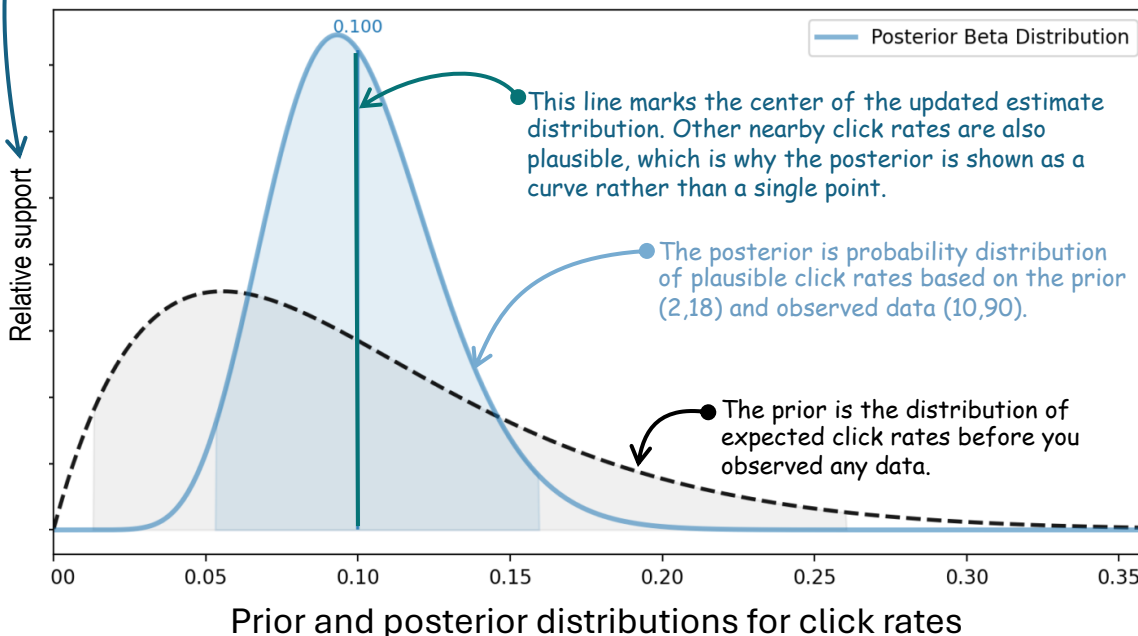
What does relative support mean?

Think of relative support as the curve's way of showing emphasis. Taller parts of the curve mark click rates the model supports more strongly. Lower parts mark click rates it supports less strongly.

The curve is taller around 10% than around 15%, so the model treats click rates near 10% as more plausible than click rates near 15%.

How you might report this result

If this organization faced a similar phishing attack, the estimated click rate would be about 10%. Rates near 15% are still plausible, but receive less support from the model. Click rates beyond 20% are unlikely.



The x-axis continues to 1.0 or 100%, but it is cut off here for space. Beyond 35%, the posterior curve is near zero, so click rates above 35% receive almost no posterior support.